

EGR6301 — Етичний хакінг

Лабораторна робота 2: Сканування та виявлення сервісів

Тиждень 2

Орієнтовний час: 90 хвилин

Максимальний бал: 100

Інструменти: Kali Linux VM, Metasploitable 2 VM, VirtualBox (Host-Only)

Здача: PDF-звіт зі скріншотами, формат: Lab2_Прізвище_Група.pdf

Викладач: Тетяна Василівна Бабенко, д.т.н., професор

Цілі навчання

1. Виконати сканування виявлення хостів nmap -sn та інтерпретувати результати
2. Провести SYN-сканування (-sS) та TCP Connect (-sT) і порівняти результати
3. Виконати визначення версій сервісів (-sV) та інтерпретувати інформацію про версії
4. Провести UDP-сканування (-sU) обраних портів
5. Побудувати повну таблицю карти сервісів з 10+ сервісами
6. Застосувати моделювання загроз для пріоритизації виявлених сервісів за рівнем ризику
7. Зберегти результати сканування у файли (-oN, -oX)
8. Задokumentувати всі дії скріншотами та професійним аналізом

Частина 1 — Концептуальні основи (25 балів)

Дайте відповіді на питання. Покажіть хід міркувань. Мінімум 3–4 речення на відповідь.

Завдання 1.1 — Вибір типу сканування (5 балів)

Ви проводите пентест корпоративної мережі. Scope of Work містить 50 IP-адрес. У вас 8 годин. Опишіть стратегію сканування: які типи в якому порядку та чому? Посилайтесь на конкретні прапорці Nmap (-sn, -sS, -sV, -sU, -p-).

Завдання 1.2 — SYN vs TCP Connect (5 балів)

Поясніть технічну різницю між SYN scan (-sS) та TCP Connect scan (-sT). Опишіть обмін пакетами для кожного. Чому SYN scan називають «напівз'єднанням»? В якій ситуації -sT кращий за -sS?

Завдання 1.3 — Труднощі UDP-сканування (5 балів)

Поясніть, чому UDP-сканування фундаментально повільніше та менш надійне за TCP. Яка характеристика протоколу ускладнює визначення відкритості UDP-порту? Назвіть три критичних сервіси на UDP та поясніть, чому ігнорування UDP — значний пробіл у пентесті.

Завдання 1.4 — Важливість визначення версій (5 балів)

Базове сканування показує: порт 21 відкритий. Сканування версій виявляє: vsftpd 2.3.4. Поясніть, чому інформація про версію перетворює це з «відкритого порту» на «критичну вразливість». Посилайтесь на CVE-2011-2523 та поясніть, що таке backdoor у цьому контексті.

Завдання 1.5 — Процес моделювання загроз (5 балів)

Опишіть чотири кроки моделювання загроз (Інвентаризація → Ідентифікація → Пріоритизація → Планування). Для кожного кроку наведіть конкретний приклад з результатів сканування Metasploitable 2. Поясніть, як CVSS-оцінки використовуються на кроці Пріоритизації.

Частина 2 — Практичні термінальні завдання (45 балів)

Виконайте всі завдання. Надайте скріншоти з командою TA виводом. Напишіть пояснення 2–3 речення.

Завдання 2.1 — Виявлення хостів (5 балів)

Виконайте виявлення хостів:

```
nmap -sn 192.168.56.0/24
```

а) Скріншот повного виводу. б) Таблиця виявлених хостів (IP, статус, MAC). с) Поясніть, які зонди відправляє -sn (ICMP echo, TCP SYN:443, TCP ACK:80, ICMP timestamp).

Завдання 2.2 — SYN Scan (8 балів)

SYN-сканування Metasploitable 2:

```
sudo nmap -sS 192.168.56.101
```

а) Скріншот. б) Підрахуйте кількість відкритих портів. с) Повторіть з контролем таймінга:

```
sudo nmap -sS -T4 192.168.56.101
```

д) Порівняйте тривалість. Що швидше і чому?

Завдання 2.3 — Порівняння TCP Connect (5 балів)

TCP Connect сканування:

```
nmap -sT 192.168.56.101
```

а) Скріншот. б) Порівняйте з SYN scan з Завдання 2.2. Порти ідентичні? с) Поясніть ключову різницю на мережевому рівні.

Завдання 2.4 — Визначення версій сервісів (10 балів)

Комплексне сканування версій:

```
nmap -sV -sC -p- 192.168.56.101
```

а) Скріншот ПОВНОГО виводу. б) Створіть повну таблицю карти сервісів: Порт | Протокол | Стан | Сервіс | Версія | Оцінка ризику Включіть ВСІ сервіси (очікується 15+ записів з -p-). с) Для щонайменше ТРЬОХ сервісів поясніть, чому ви присвоїли такий рівень ризику.

Завдання 2.5 — UDP-сканування (5 балів)

Цільове UDP-сканування:

```
sudo nmap -sU -p 53,67,68,69,111,161,162,514 192.168.56.101
```

а) Скріншот. б) Які UDP-порти open? Які open|filtered? с) Поясніть різницю між 'open' та 'open|filtered' в UDP.

Завдання 2.6 — Збереження результатів (5 балів)

Збережіть результати у двох форматах:

```
nmap -sV -oN scan_normal.txt -oX scan_xml.xml 192.168.56.101
```

а) Скріншот: ls -la scan_* б) Покажіть: head -20 scan_normal.txt с) Поясніть, чому збереження в обох форматах важливе.

Завдання 2.7 — NSE-скрипти вразливостей (7 балів)

Скрипти виявлення вразливостей:

```
nmap --script vuln 192.168.56.101
```

а) Скріншот ключових знахідок. б) Перерахуйте вразливості, виявлені автоматично. с) Порівняйте з ручною картою сервісів з Завдання 2.4. Чи знайшов --script vuln щось нове?

Частина 3 — Моделювання загроз (20 балів)

Використовуючи результати з Частини 2, виконайте структуроване моделювання загроз.

Завдання 3.1 — Пріоритизація векторів атаки (12 балів)

З повної карти сервісів (Завдання 2.4) оберіть П'ЯТЬ сервісів з найвищим ризиком.

Для кожного створіть картку вектора атаки:

Сервіс: [назва та версія] Порт: [номер/протокол] CVE: [якщо відомий] Рівень ризику: Critical / High / Medium / Low Складність експлуатації: Trivial / Moderate / Complex Потенційний вплив: [який доступ дасть успішна експлуатація?] Рекомендований метод: [модуль Metasploit, ручний exploit, brute-force тощо]

Ранжуйте всі п'ять у рекомендованому порядку атаки та обґрунтуйте.

Завдання 3.2 — Відображення фаз PTES (8 балів)

Відобразіть лабораторні завдання на фази PTES:

а) Яка фаза — Завдання 2.1-2.3? Мета? б) Яка фаза — Завдання 2.4-2.7? с) Моделювання загроз у Завданні 3.1 — яка фаза? d) Яка НАСТУПНА фаза? Що конкретно ви б зробили першим? е) Чому все це документується у фазі Reporting?

Частина 4 — Безпека та професійна перспектива (10 балів)

Дайте відповіді в контексті професійного тестування.

Завдання 4.1 — Виявлення та маскування сканування (5 балів)

а) SYN scan у Завданні 2.2 генерував мережевий трафік. Як IDS може виявити вашу активність? б) Який параметр таймінга Nmap ви б обрали для зниження шансів виявлення? Чому? с) Чи етичне маскування сканування? За яких обставин це прийнятно?

Завдання 4.2 — Executive Summary (5 балів)

Напишіть Executive Summary (150–200 слів) як для реального звіту пентесту: а) Score виконаного сканування б) Кількість відкритих портів та сервісів с) Топ-3 критичних знахідки d) Рекомендовані негайні дії

Пишіть нетехнічною мовою, зрозумілою CEO або СТО.

Критерії оцінювання

Компонент	Бали	Критерії
Частина 1 — Концептуальні основи	25	Коректність міркувань, глибина технічних пояснень, PTES/CVSS посилання
Частина 2 — Практичні завдання	45	Правильні команди, чіткі скріншоти, повна карта сервісів, якість аналізу
Частина 3 — Моделювання загроз	20	Якість векторів атаки, точність PTES, обґрунтування пріоритизації
Частина 4 — Перспектива безпеки	10	Розуміння IDS, якість executive summary, професійний тон
РАЗОМ	100	

Інструкції з подання

- Формат: один PDF-документ
- Назва: Lab2_Прізвище_Група.pdf (напр., Lab2_Іванова_КБ401.pdf)
- Скріншоти — повне вікно терміналу
- Таблиця сервісів — ВСІ виявлені сервіси (мінімум 10)
- Подати через Platonus до дедлайну
- Пізня здача: -10% за день, максимум 3 дні